

# מודול 15 — הנדסה חברתית ופישיון

חומר לימוד

1 יחידות

## תוכן העניינים

1. מודול 15 — הנדסה חברתית ופישנינג (Social Engineering & Phishing)

# מודול 15 — הנדסה חברתית ופשינג (Social Engineering & Phishing)

**מטרות המודול:** להבין את החוליה החלשה ביותר באבטחה — האדם. נלמד את עקרונות ההשפעה הפסיכולוגיים שתוקפים מנצלים, סוגי מתקפות (Phishing, Vishing, Pretexting, Baiting), נבנה **קמפיין פשינג מבוקר** (GoPhish) וננהל **OSINT** לאיסוף מטרות. המודול כולל דגש כבד על **אתיקה** — כאן ההשלכות האנושיות ממשיות.

**קבצים:** README.md · missions.md · solutions.md · practice.md · slides.md.

**למה זה חשוב? ~90% מהפריצות מתחילות בפשינג.** אפשר להשקיע מיליונים בחומות אש — משתמש אחד שלוחץ על לינק עוקף את הכול. בדיקת חדירה מקצועית (במיוחד PNPT) **חייבת** לכלול רכיב הנדסה חברתית.

## תוכן העניינים

1. החוליה האנושית
2. עקרונות ההשפעה (צ'לדיני)
3. סוגי מתקפות הנדסה חברתית
4. OSINT — איסוף מודיעין על המטרה
5. אנטומיה של מייל פשינג
6. בניית קמפיין פשינג (GoPhish)
7. כלים נוספים (SET, evilginx)
8. אתיקה, חוק והגנה

## 15.1 החוליה האנושית

טכנולוגיה אפשר להקשיח; אנשים קשה יותר. הנדסה חברתית מנצלת **רגש והרגלים** — לא באגים בקוד: - **סמכות** — “המנכ”ל ביקש”. - **דחיפות** — “החשבון שלך יינעל תוך שעה!”. - **פחד** — “זוהתה פעילות חשודה”. - **סקרנות / תאוות בצע** — “זכית!”, “ראה מי צפה בפרופיל שלך”.

## 15.2 עקרונות ההשפעה (צ'לדיני)

ששת עקרונות ההשפעה של רוברט צ'לדיני, שתוקפים מנצלים:

| עיקרון                      | ניצול בהתקפה                   |
|-----------------------------|--------------------------------|
| Reciprocity (הדדיות)        | "נתתי לך משהו, עכשיו תעזור לי" |
| Commitment (עקביות)         | הסכמה קטנה → הסכמה גדולה       |
| Social Proof (הוכחה חברתית) | "כל העובדים כבר עדכנו"         |
| Authority (סמכות)           | התחזות למנהל/IT/רשות           |
| Liking (חיבה)               | בניית קרבה ואמון לפני הבקשה    |
| Scarcity (מחסור)            | "הצעה מוגבלת", "רק היום"       |

💡 רוב מיילי הפישינג המוצלחים משלבים סמכות + דחיפות: "מחלקת IT — אפס את הסיסמה תוך 24 שעות אחרת תיחסם".

### 15.3 סוגי מתקפות הנדסה חברתית

| מתקפה          | ערוץ    | תיאור                                      |
|----------------|---------|--------------------------------------------|
| Phishing       | אימייל  | מייל המוני מזויף עם לינק/קובץ זדוני        |
| Spear Phishing | אימייל  | פישנינג ממוקד לאדם ספציפי (מותאם אישית)    |
| Whaling        | אימייל  | ספיר-פישנינג לבכיר (מנכ"ל, סמנכ"ל)         |
| Vishing        | טלפון   | הנדסה חברתית קולית ("מדבר נציג הבנק")      |
| Smishing       | SMS     | פישנינג בהודעות טקסט                       |
| Pretexting     | כל ערוץ | בניית תרחיש כיסוי אמין ("אני הטכנאי החדש") |
| Baiting        | פיזי    | פיתיון — USB "אבוד" בחניון עם תווית מפתה   |
| Tailgating     | פיזי    | כניסה למתחם בעקבות עובד מורשה              |

**Spear Phishing** הוא היעיל ביותר בבדיקות אמיתיות — מייל מותאם אישית (שם, תפקיד, פרויקט אמיתי) מקבל שיעורי לחיצה גבוהים בהרבה ממייל גנרי.

### 15.4 OSINT — איסוף מודיעין על המטרה

לפני מתקפה ממוקדת — אוספים מידע גלוי (Open Source Intelligence):

```
# איסוף כתובות מייל ושמות מהדומיין
theHarvester -d company.com -b all

# מיפוי נוכחות דיגיטלית:
# - LinkedIn, תפקידים, טכנולוגיות
# - (firstname.lastname@) אתר החברה: מבנה מיילים
# - GitHub, מפתחות שדלפו
# - Google Dorking: site:company.com filetype:pdf
```

כלים נוספים: **Maltego** (מיפוי קשרים גרפי), **hunter.io** (מיילים), **haveibeenpwned** (דליפות).

OSINT  הוא הבסיס לספיר-פישנינג משכנע: ככל שתדע יותר על הקורבן (תפקיד, פרויקטים, קולגות) — כך המייל יראה אמין יותר. זה מתחבר ישירות למודול 5 (Recon).

## 15.5 אנטומיה של מייל פישנינג

מייל פישנינג משכנע כולל: 1. **כתובת שולח מזויפת/דומה** — `it-suport@company.com` (שים לב לשגיאת הכתיב), או `Display Name` מזויף. 2. **נושא דחוף** — “פעולה נדרשת: אימות חשבון”. 3. **מיתוג אמין** — לוגו, צבעים, חתימה של הארגון. 4. **קריאה לפעולה** — לינק (“לחץ כאן”) או קובץ מצורף. 5. **דף נחיתה מזויף** — עמוד התחברות שנראה אמיתי, שולח את הפרטים לתוקף.

סימני זיהוי (להדרכת עובדים):

- ⚠ שולח לא מוכר / דומיין שגוי במעט
- ⚠ דחיפות ואיומים
- ⚠ שגיאות כתיב ותרגום מכונה
- ⚠ האמיתי שלו שונה מהטקסט (רחף מעליו!) URL-לינק שה
- ⚠ בקשה לפרטי התחברות / פרטים אישיים

## 15.6 בניית קמפיין פישנינג (GoPhish)

**GoPhish** הוא framework חינומי לניהול קמפיין פישנינג **מבוקר** (מדידת מודעות עובדים):

```
# הרצה:
./gophish
# ממשק ניהול ב https://localhost:3333
```

שלבי בניית קמפיין: 1. **Sending Profile** — שרת ה-SMTP לשליחה. 2. **Landing Page** — שבט (clone) של דף התחברות אמיתי; לוכד credentials ומפנה לאתר האמיתי. 3. **Email Template** — תבנית המייל (עם משתנים: `{{.FirstName}}`, `{{.URL}}`). 4. **Users & Groups** — רשימת היעדים (מ-OSINT). 5. **Campaign** — הרצה + מעקב: מי פתח, מי לחץ, מי הזין פרטים.

GoPhish  מפיק **דוח מדדים**: אחוז פתיחה, אחוז לחיצה, אחוז מסירת פרטים — בדיוק מה שהלקוח צריך למדוד את מודעות העובדים ולתכנן הדרכות.

## 15.7 כלים נוספים (SET, evilginx)

- **SET (Social-Engineer Toolkit)** — ארגז כלים קלאסי: Credential Harvester (שבט אתר), Spear-Phishing, יצירת Payloads.

```
sudo setoolkit
# 1) Social-Engineering Attacks → 2) Website Attack → 3) Credential Harvester
```

- **evilginx2** — פרוקסי מתקדם שעוקף **MFA** ע"י גניבת ה-**session token** (לא רק הסיסמה) — מדגים מדוע פשינג עדיין מסוכן גם עם 2FA.
- **King Phisher** — חלופה ל-GoPhish.

⚠ evilginx וגניבת session מדגימים ללקוח שגם MFA אינו "כדור כסף" — אך זהו כלי רב-עוצמה שיש להשתמש בו **אך ורק** בהרשאה מפורשת ובתיעוד מלא.

## 15.8 אתיקה, חוק והגנה

**כאן האתיקה קריטית מתמיד** — מדובר באנשים אמיתיים: - **הרשאה בכתב** מההנהלה, עם **Scope** ברור (מי מותר, מי לא — אף פעם לא HR/רפואה/איש). - **אל תשפיל / תלחיץ** מעבר לנדרש; המטרה חינוך, לא ענישה. - **דיווח מרוכז** — לא "שיימינג" של עובדים שנפלו; מדווחים אחוזים, לא שמות. - **מחיקת נתונים** שנאספו (credentials) בסיום.

**הגנה (להמלצות בדוח):** - **הדרכות מודעות** תקופתיות + סימולציות פשינג. - **MFA** בכל מקום (מקטין נזק מגניבת סיסמה). - **סינון מייל** (SPF/DKIM/DMARC, אנטי-פשינג). - **תרבות "שאל אם לא בטוח"** — קל לדווח על מייל חשוד.

⚖ בדיקת הנדסה חברתית מודדת **מוכנות ארגונית** ומחנכת — לא "תופסת" עובדים. הצג את התוצאות כהזדמנות לשיפור, לעולם לא כהאשמה אישית.

## סיכום המודול

- **האדם** הוא החוליה החלשה; ~90% מהפריצות מתחילות בפשינג.
- תוקפים מנצלים **עקרונות השפעה** (סמכות, דחיפות, פחד) — לא באגים.
- סוגים: **Phishing** (הכי יעיל), **Spear Phishing**, Vishing, Pretexting, Baiting.
- **OSINT** (theHarvester, LinkedIn, Maltego) מזין ספיר-פשינג משכנע.

- **GoPhish / SET** בונים קמפיין מבוקר עם מדדים; **evilginx** עוקף MFA.
- **אתיקה קריטית:** הרשאה, Scope, דיווח מרוכז ללא שיימינג; הגנה = הדרכות + MFA + סינון.

**מה הלאה?**

→ **missions.md** — תרגילים · **solutions.md** — פתרונות · **practice.md** — תרגול ותרחישים →  
מודול 16 — כתיבת דוח ותיעוד

← חזרה למפת הקורס